

Le fichier que tu prépares est le fichier de réponse pour une Autorité de Certification (CA) d'Entreprise ou Autonome, souvent nommé `CAPolicy.inf`. Si tu l'appliques **avant** l'installation (ou le renouvellement du certificat de la CA racine), voici les paramètres cruciaux, importants et optionnels que tu devrais y rajouter pour avoir une infrastructure PKI (ADCS) robuste et conforme aux meilleures pratiques d'entreprise.

Le fichier `CAPolicy.inf` optimisé pour ton diagnostic

Voici le fichier enrichi avec les blocs essentiels pour un déploiement propre :

Ini, TOML

[Version]

Signature="\$Windows NT\$"

[Certsrv_Server]

Configuration de la clé et validité de la CA Racine (Root CA)

RenewalKeyLength=4096

RenewalValidityPeriod=Years

RenewalValidityPeriodUnits=10

AlternateSignatureAlgorithm=0

Configuration des listes de révocation (CRL) initiales

CRLPeriod=Weeks

CRLPeriodUnits=1

CRLDeltaPeriod=Days

CRLDeltaPeriodUnits=1

CRLOverlapPeriod=Hours

CRLOverlapPeriodUnits=12

[EnhancedKeyUsageExtension]

IMPORTANT SÉCURITÉ : Empêche cette CA d'être détournée pour n'importe quoi

OID=1.3.6.1.5.5.7.3.1 ; Server Authentication (HTTPS)

OID=1.3.6.1.5.5.7.3.2 ; Client Authentication

OID=1.3.6.1.4.1.311.20.2.2 ; Smartcard Logon

[Extensions]

Désactivation de la publication des CRL sur le site Web IIS par défaut (optionnel mais propre)

Critical=No

Explications des ajouts (Pourquoi c'est important ?)

1. La gestion fine des CRL (Listes de Révocation) — *Important*

Dans ton fichier initial, tu as mis une validité de CRL d'un mois (`CRLPeriod=Months`, `CRLPeriodUnits=1`). En entreprise, c'est trop long pour une CA qui délivre des certificats serveurs ou d'ordinateurs. Si un certificat est compromis, il faut attendre un mois pour que l'information soit publiée.

- **`CRLPeriod=Weeks` et `CRLPeriodUnits=1`** : La CRL principale est publiée toutes les semaines.
- **`CRLDeltaPeriod=Days` et `CRLDeltaPeriodUnits=1`** : Tu actives les **Delta CRL** (les mini-mises à jour quotidiennes des certificats révoqués). C'est indispensable

pour que tes serveurs IIS valident en temps réel la chaîne de certification sans surcharger le réseau.

- **CRLOverlapPeriod** : Permet de définir une période de chevauchement pour éviter qu'une CRL n'expire avant que la nouvelle ne soit propagée.

2. Le bloc [EnhancedKeyUsageExtension] — *Sécurité / Optionnel*

Par défaut, si rien n'est spécifié, une CA racine peut signer des certificats pour **tous les usages possibles** (All Application Policies).

- En rajoutant ce bloc, tu restreins techniquement ta CA à ne délivrer que des certificats pour de l'**Authentification Serveur (HTTPS)**, de l'**Authentification Client** et du **Logon par carte à puce/jeton**.
- C'est une excellente pratique de durcissement (Hardening) recommandée par l'ANSSI et Microsoft.

3. La politique d'extension d'application (Policies) — *Optionnel Avancé*

Si tu veux aller encore plus loin pour simuler une vraie PKI de production, tu peux définir un identifiant d'objet (OID) de politique pour indiquer que ta CA suit une politique de sécurité spécifique. Cela se fait via un bloc [DeploymentStatementExtension], mais pour ton lab de diagnostic actuel, ce n'est pas strictement nécessaire.

Point d'attention pour ton installation ADCS

Comme tu vas reconstruire un domaine tout neuf (optimedit.eu), veille bien à installer le rôle ADCS **après** avoir promu ton serveur opt-dc02 en Contrôleur de Domaine et configuré les DNS.

Pense à placer ce fichier sous le nom exact de **CAPolicy.inf** dans le dossier **C:\Windows** avant de lancer l'assistant de configuration ADCS (ou ton script PowerShell d'installation). Le moteur d'ADCS ira le lire automatiquement à ce moment-là pour configurer la clé privée de ta CA.

C'est une excellente démarche, tiens-moi au courant si ce nouveau domaine et cette nouvelle instance Ansible résolvent enfin le mystère du Test-ComputerSecureChannel en False !

BLOCAGE

Concernant [EnhancedKeyUsageExtension] = blocage ?

C'est une excellente remarque, et tu as totalement raison de soulever ce point. Si tu laisses cette section [EnhancedKeyUsageExtension] dans le fichier CAPolicy.inf de ta **CA Racine (Root CA)**, tu vas te bloquer pour la suite.

Voici pourquoi c'est un piège pour tes futurs modèles (templates) et comment le corriger immédiatement.

Le piège du bloc [EnhancedKeyUsageExtension] dans la CA Racine

Quand tu définis des OID dans le fichier CAPolicy.inf au moment de l'installation de la CA Racine, tu appliques une **contrainte matérielle stricte sur le certificat de la CA elle-même**.

- **Ce que cela fait** : Le certificat auto-signé de ton opt-dc02 (la racine) contiendra l'extension EKU contenant *uniquement* les 3 OID spécifiés.
- **La conséquence sur tes futurs templates** : Une CA ne peut **jamais** délivrer un certificat avec un usage qu'elle ne possède pas elle-même dans son propre certificat.
 - Si plus tard tu veux créer un template pour du **Chiffrement de fichier (EFS)**, de la **Signature de code**, ou des **Certificats d'ordinateurs génériques (Domain Controller / Machine)**, ta CA refusera catégoriquement de les délivrer ou ils seront systématiquement invalides, car l'usage n'est pas approuvé par la racine.

Quant au **Smartcard Logon**, si tu n'as pas de projet de déploiement de cartes à puce ou d'authentification forte YubiKey à court terme, traîner cet OID est inutile et complexifie la chaîne pour rien.

La solution : Retirer le bloc et gérer la sécurité par les Templates

Pour ton nouveau DC et ta nouvelle forêt, la meilleure pratique consiste à **supprimer complètement** cette section du fichier CAPolicy.inf.

Voici le fichier exact que tu dois appliquer dans C:\Windows\CAPolicy.inf :

```
Ini, TOML
[Version]
Signature="$Windows NT$"
```

```
[Certsrv_Server]
RenewalKeyLength=4096
```

```
RenewalValidityPeriod=Years  
RenewalValidityPeriodUnits=10  
AlternateSignatureAlgorithm=0
```

```
# Configuration des listes de révocation (CRL)  
CRLPeriod=Weeks  
CRLPeriodUnits=1  
CRLDeltaPeriod=Days  
CRLDeltaPeriodUnits=1  
CRLOverlapPeriod=Hours  
CRLOverlapPeriodUnits=12
```



Comment sécuriser tes certificats sans ce bloc ?

Ne t'inquiète pas pour la sécurité : le fait de retirer ce bloc ne transforme pas ta PKI en passoire. C'est le comportement standard en entreprise (Modèle d'architecture PKI à 2 niveaux ou Enterprise Root).

Le contrôle de sécurité se fait au niveau des **Modèles de certificats (Certificate Templates)** dans la console certtmpl.msc :

1. Ta CA Racine aura le droit de tout signer (All Application Policies).
2. C'est toi, via Ansible ou l'interface ADCS, qui définirás précisément sur chaque modèle (ex: ton modèle personnalisé pour IIS) les extensions EKUs requises, par exemple **Authentification Serveur (1.3.6.1.5.5.7.3.1)** uniquement.

De cette façon, ton infrastructure reste ultra-sécurisée, mais tu gardes une flexibilité totale pour créer n'importe quel type de template à l'avenir dans ton nouveau domaine optimedit.eu.

[Extensions]

Désactivation de la publication des CRL sur le site Web IIS par défaut (optionnel mais propre)
Critical=No

Pour répondre directement à ta question : **Non, ce n'est pas critique pour le fonctionnement de ton serveur IIS local**, mais c'est une excellente pratique de **durcissement (Hardening) et de propreté** pour ton infrastructure Active Directory et réseau.

Pour bien comprendre pourquoi ce bloc existe et son impact sur IIS, il faut regarder ce qu'ADCS fait par défaut lors de son installation.

Qu'est-ce que le "site Web IIS par défaut" d'ADCS ?

Lorsque tu installes le rôle ADCS (Autorité de Certification) sur un serveur de domaine, Microsoft installe (ou configure) souvent une extension web appelée **CertSrv** (<https://ton-dc/CertSrv>).

Par défaut, l'autorité de certification est configurée pour publier ses listes de révocation (les fichiers .crl) dans un dossier qui est exposé sur ce site web IIS.



Pourquoi utilise-t-on le bloc [Extensions] avec Critical=No ?

Dans le fichier CAPolicy.inf, ce bloc sert à dire à Windows : *"Au moment de générer le certificat de la CA, ne marque pas les chemins de publication par défaut (CDP/AIA) comme critiques, et prépare le terrain pour que je puisse nettoyer les extensions."*

Si tu ne mets pas cette configuration ou si tu laisses ADCS publier ses CRL sur le site IIS par défaut du Contrôleur de Domaine, cela pose deux problèmes majeurs en entreprise :

1. Sécurité (Hardening du DC)

Un Contrôleur de Domaine (opt-dc02) a pour vocation première d'être ultra-sécurisé. Y laisser tourner un serveur Web IIS public ou actif simplement pour distribuer des fichiers de CRL augmente la **surface d'attaque** du DC. Les entreprises préfèrent désactiver IIS sur les DC et publier les CRL ailleurs.

2. Performance et Fiabilité des serveurs IIS applicatifs (comme tes VM)

Lorsque tes serveurs IIS (Site_achat, Site_blog, etc.) reçoivent une connexion HTTPS, ils doivent vérifier si le certificat du client ou de la chaîne n'est pas révoqué. Pour cela, ils téléchargent la CRL.

- Si la CRL est hébergée sur le site web par défaut du DC et que ce site web plante, est surchargé, ou que les droits d'accès HTTP sont mal configurés, tes serveurs IIS applicatifs n'arriveront plus à joindre la CRL.
- **Résultat** : Tes sites IIS mettront du temps à répondre (Time-out) ou renverront des erreurs d'accès SSL à tes utilisateurs car ils refuseront de valider un certificat dont la CRL est inaccessible.

Quelle est la bonne pratique en Entreprise ?

Puisque tu rebâtis une forêt propre (optimedit.eu), l'approche professionnelle consiste à :

1. Laisser ce bloc dans le CAPolicy.inf pour éviter qu'ADCS ne verrouille des chemins HTTP par défaut obsolètes.
2. Une fois ta CA installée, aller dans la console certsrv.msc (Propriétés de la CA > Onglet **Extensions**).
3. **Décocher** la publication HTTP par défaut qui pointe vers le site IIS du DC.
4. **Utiliser à la place le protocole LDAP (intégré à l'Active Directory)** : C'est le moyen le plus propre et le plus robuste pour un environnement interne. Tes serveurs IIS interrogeront directement l'AD (via le catalogue global) pour télécharger la CRL, sans avoir besoin qu'un serveur Web IIS tourne sur ton contrôleur de domaine.

En résumé, ce paramètre n'est pas obligatoire pour que tes sites fonctionnent aujourd'hui, mais il est **fortement recommandé** pour t'éviter des erreurs de validation de chaîne de certificat et des lenteurs sur tes serveurs IIS applicatifs à l'avenir.